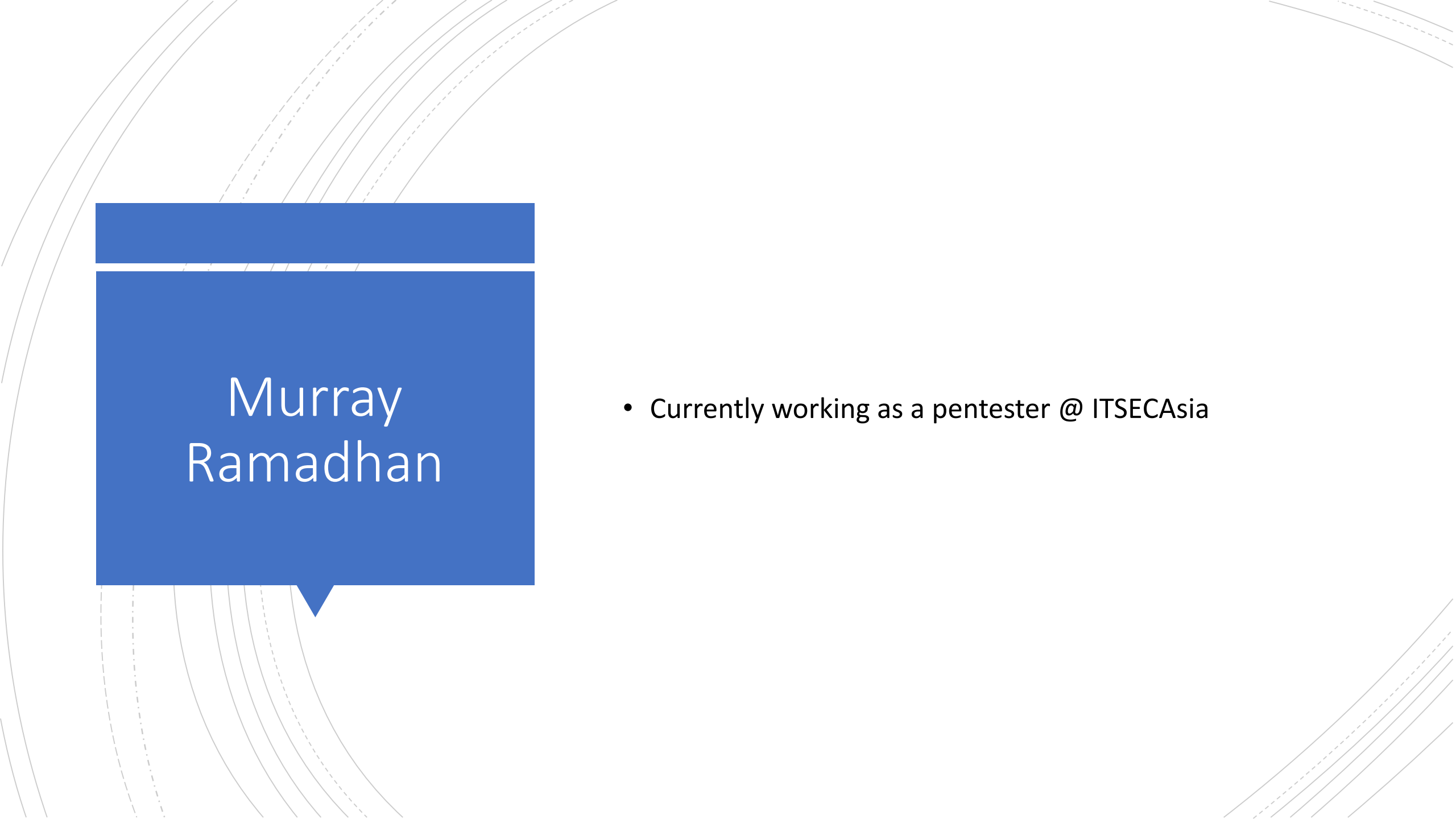


Modern Phishing Campaign

08 Maret 2019

The background of the slide features a series of thin, curved lines in a light gray color, creating a sense of motion and depth. These lines are more prominent on the left side and fade out towards the right.

Murray
Ramadhan

- Currently working as a pentester @ ITSECAAsia

Why you need phishing campaign?

- Can masquerade as a legitimate email or website
 - Brazil is one of the top countries for phishing
- To harvest or steal credentials, and take over account
- Opportunistic attacks, or cast into organizational-wide
 - ex: Special Ear malware spread themselves with phishing email
- Target specific industries or organization
 - ex: FIN4 targeting 100 companies targeting most confidential information.
- Can hit any organization
 - No companies was immune to phishing attacks, security firm kaspersky lab was victim to the malware Duqu 2.0, which originated from an infected email attachment sent to its sales team

The background of the slide features several thin, curved lines in a light gray color, some solid and some dashed, creating a sense of motion or a stylized globe. A blue speech bubble is positioned on the left side, containing the main text.

Do you need a
phishing
campaign?

- Your company can initiate wire-transfer
- Your company have most valuable information
- Your company are freaking rich
- Your company does not care with reputation

2017 Statistics

Relative message volume for the top 20 phishing lures in 2017

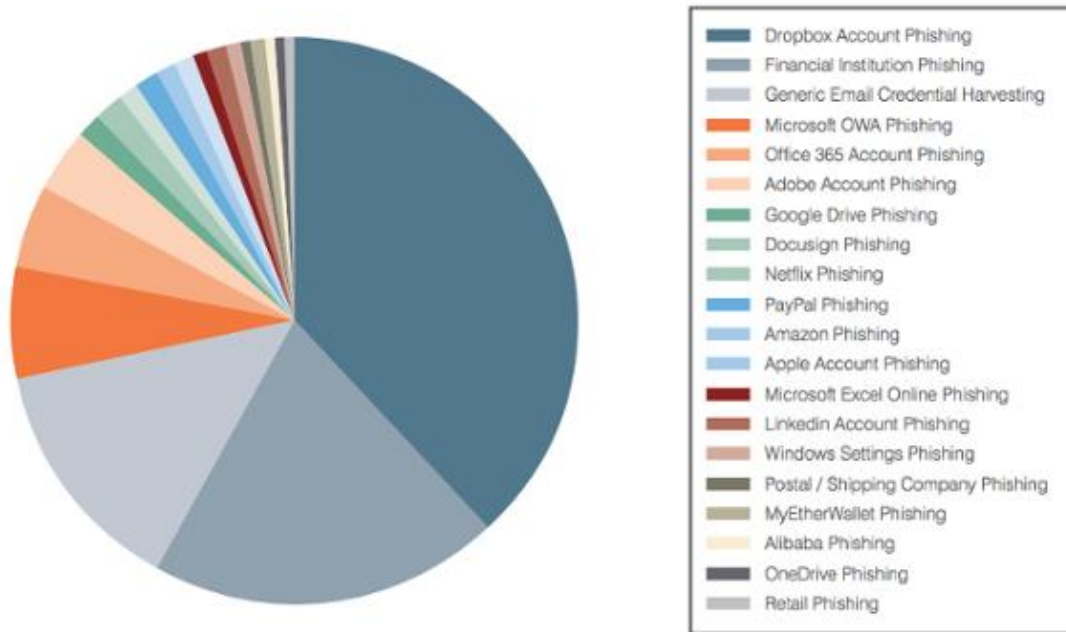


Figure 1: Relative volumes associated with the top phishing attack lures

Relative Click Rates For Most-Clicked Lures

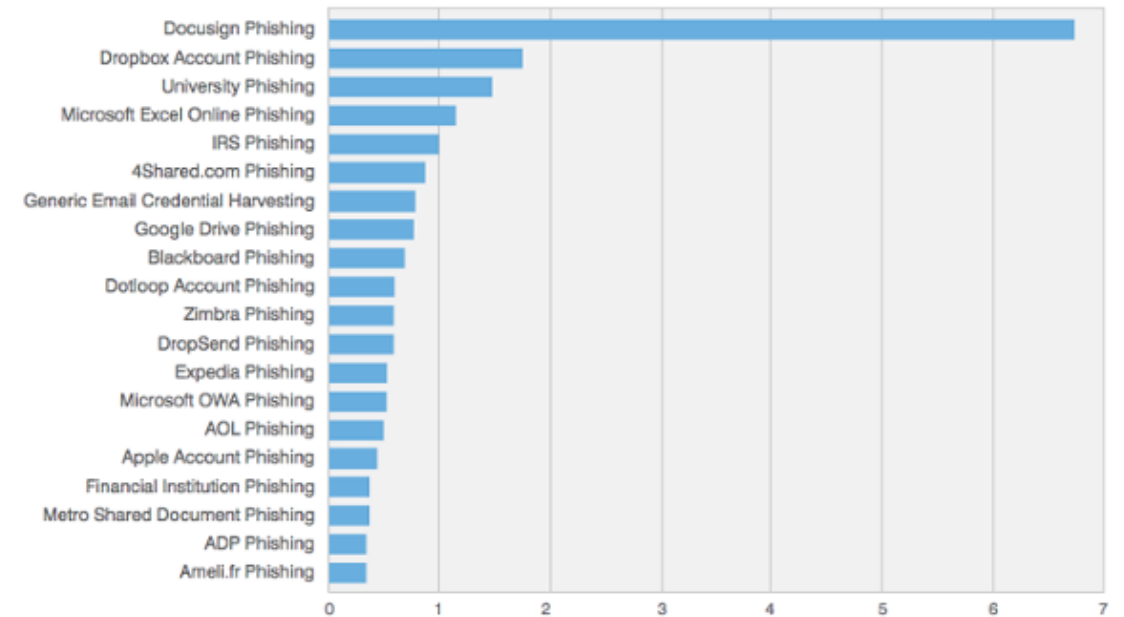


Figure 2: Average click rates for the top 10 lures

The background of the slide features several thin, curved lines in shades of gray, some solid and some dashed, creating a modern, abstract design. A blue speech bubble is positioned on the left side, containing the main text.

Phishing
campaign can
be successful
if..

- The company rely TOO MUCH on technologies
 - USD 1M Firewall vs USD 0 Human stupidity
- The employee too easy as targeted attacks
 - 30% phishing victim WILL open the email
 - 10% will click the link
- Lack of security awareness
 - They do not know what is phishing
 - What is malware
 - The IT Things must be right
 - IT Security and Policy things make them not productive

Impacts of Phishing



Phishing Kit Infrastructure

01

CDN

- Preparing Servers
- Preparing Tools and SMTP Relay

02

Campaign

- Preparing Cloned Website and Domain
- Preparing Phishing Email Template

03

Running Campaign

- Tracking Link
- Infected Attachments
- Credentials Form
- CnC Attacks

WOW! **ptkai.id** tersedia untuk Anda! Jangan lewatkan jika domain ini berarti buat Anda.

Rp. 250,000,-

Beli

.com

Tidak tersedia

.web.id

Tambahkan

Domain lainnya

WOW! **herminahospitals.id** tersedia untuk Anda! Jangan lewatkan jika domain ini berarti buat
Rp. 250,000,- [Beli](#)

.com

Tidak tersedia

.web.id

[Tambahkan](#)

alfa-cart.id

Q Cari

Transfer

Paket Hosting

WOW! **alfa-cart.id** tersedia untuk Anda! Jangan lewatkan jika domain ini berarti buat Anda.

Rp. 250,000,-

Beli

WOW! **gopay-promo.id** tersedia untuk Anda! Jangan lewatkan jika domain ini berarti buat Anda.

Rp. 250,000,-

Beli

.com

Tambahkan

.web.id

Tambahkan

Servers

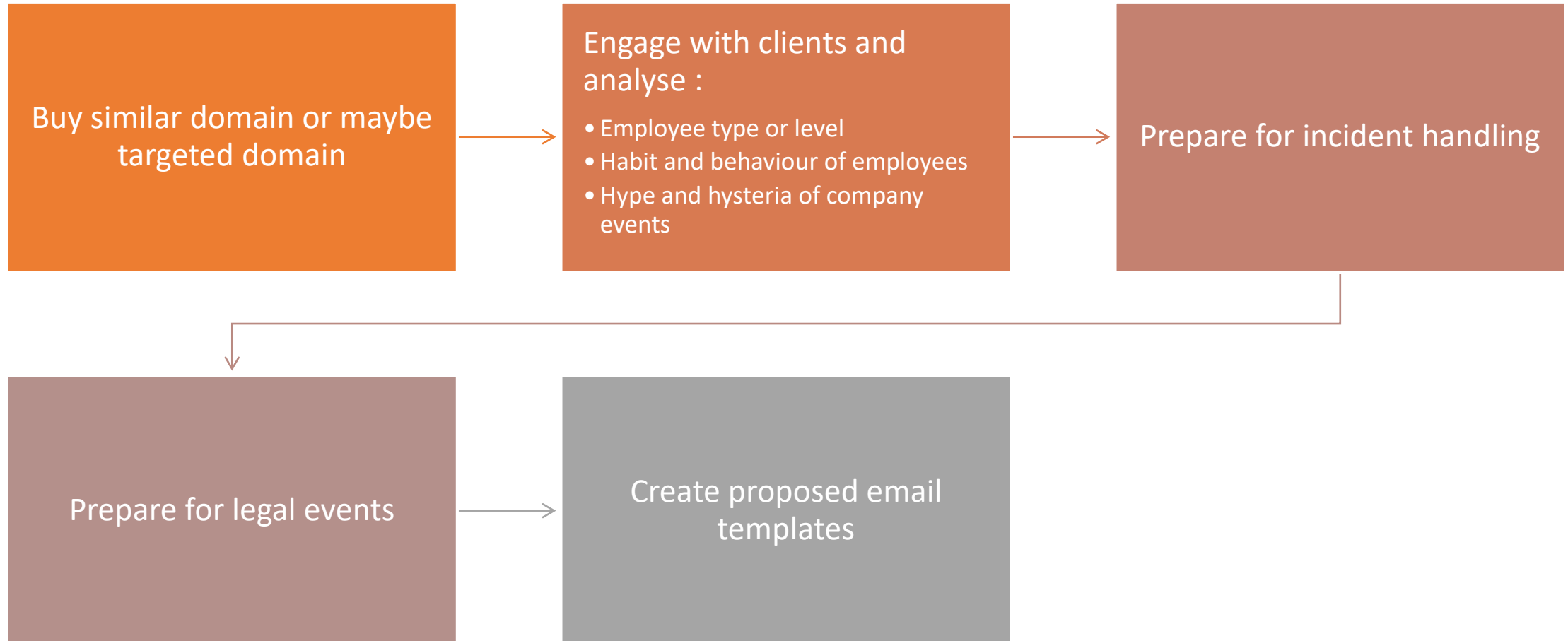
Minimal
Servers? Not
a problem

CDN should
be good

Buy SMTP
Relay services
or use google
for free

Pentester
friendly

Campaign



Running Campaign

Pick one of scenario :

- Spear Phishing
 - Targeted attacks, specific issues to the group
- Whaling
 - Wire transfer, legal issues
- Credentials Stealing
- Action
- Exploit

Tools



```
root@bt:/pentest/exploits/set# ./set

      d000000o.  0 0000000000 0000000 0000000000
      .0000.' 00. 0 0000      0 0000
      0.'0000.  Y0 0 0000      0 0000
      0.'0000.  0 0000      0 0000
      0.'0000.  0 00000000000 0 0000
      0.'0000.  0 0000      0 0000
      0.'0000.  0 0000      0 0000
      0b 0.'0000. 0 0000      0 0000
      '0b. ;0.'0000 0 0000      0 0000
      'Y0000P',00P' 0 00000000000 0 0000

[----] The Social-Engineer Toolkit (SET) [----]
[----] Written by: David Kennedy (ReL1k) [----]
[----] Development Team: Thomas Werth [----]
[----] Version: 1.3.5 [----]
[----] Codename: 'Artillery Edition' [----]
[----] Report bugs to: davek@social-engineer.org [----]
[----] Follow me on Twitter: dave_relik [----]
[----] Homepage: http://www.secmaniac.com [----]
[----] Framework: http://www.social-engineer.org [----]

Welcome to the Social-Engineer Toolkit (SET). Your one
stop shop for all of your social-engineering needs..

DerbyCon 2011 Sep30-Oct02 - http://www.derbycon.com

Select from the menu:

1. Spear-Phishing Attack Vectors
2. Website Attack Vectors
3. Infectious Media Generator
4. Create a Payload and Listener
5. Mass Mailer Attack
6. Teensy USB HID Attack Vector
7. SMS Spoofing Attack Vector
8. Wireless Access Point Attack Vector
9. Third Party Modules
10. Update the Metasploit Framework
11. Update the Social-Engineer Toolkit
12. Help, Credits, and About
13. Exit the Social-Engineer Toolkit

Enter your choice: 2
```


Defeating Client's Email Server with DKIM, SPF, and DMARC

Message ID	<20190305164136.1.C56391C9463BC4B7@ [REDACTED]>
Created at:	Tue, Mar 5, 2019 at 11:41 PM (Delivered after 2 seconds)
From:	[REDACTED] Using Microsoft Outlook 14.0
To:	MUHAMMAD RAY RAMADHAN <[REDACTED]>
Subject:	[REDACTED] Aktivasi Ulang
SPF:	PASS with IP 104 [REDACTED] Learn more
DKIM:	'PASS' with domain [REDACTED] Learn more
DMARC:	'PASS' Learn more

DEMO

Your email Please.